Response to NIST Request for Information: Security Considerations for Artificial Intelligence Agents

Docket Number:	NIST-2025-0035
Federal Register:	2026-00206
Submitted by:	Pratyush Sood, Principal Consultant & IRAP Assessor
Organisation:	Tech Blaze Consulting Pty Ltd, Canberra, Australia
Date:	March 2026

About the Respondent

Pratyush Sood is an ASD-endorsed IRAP (Information Security Registered Assessors Program) Assessor with decades of experience in IT security and cybersecurity. He holds the following professional certifications:

- **CISA** — Certified Information Systems Auditor (ISACA)
- **CISM** — Certified Information Security Manager (ISACA)
- **IRAP Assessor** — ASD-endorsed, Information Security Registered Assessors Program
- **Microsoft Certified: Azure Solutions Architect Expert**
- **TOGAF 10 Enterprise Architecture Practitioner** — The Open Group

Pratyush has extensive experience assessing systems against the Australian Information Security Manual (ISM), NIST 800-53, and SOC 2 frameworks. Tech Blaze Consulting provides cybersecurity advisory services across government and enterprise sectors and is actively developing open-source tooling for AI agent identity and delegation management.

This response draws on direct operational experience deploying autonomous AI agent systems in enterprise environments, as well as extensive compliance assessment experience mapping security controls to multiple international frameworks.

Section 1 — Threat Landscape

1(a): Unique security threats, risks, or vulnerabilities affecting AI agent systems

AI agent systems introduce a fundamentally new class of security challenges that have no direct parallel in traditional software systems. The core issue is that agents combine **autonomous decision-making** with **real-world action authority** — a combination that existing security models were not designed to handle.

1. The Identity Gap

Traditional software authenticates using API keys, OAuth tokens, or service accounts — mechanisms designed for applications operated by humans. AI agents are neither human users nor traditional applications. They are autonomous entities that:

- Act on behalf of principals (humans or organisations) without real-time human oversight
- Spawn sub-agents that inherit and further delegate authority
- Operate across organisational boundaries with varying trust relationships
- Change behaviour based on their model, configuration, and prompt context

Current identity mechanisms provide no standard way for an agent to cryptographically prove *who it is*, *what it is authorised to do*, or *on whose behalf it acts*. This creates an identity vacuum where agents operate with implicit trust rather than verifiable credentials.

2. Delegation Chain Opacity

In multi-agent systems, authority flows through delegation chains: a human authorises Agent A, which delegates to Agent B, which sub-delegates to Agent C. Today, these chains are typically opaque — there is no standard mechanism to:

- Trace the full delegation path from a leaf agent back to the authorising human
- Verify that each delegation step preserved or narrowed the scope of authority
- Detect privilege escalation where a sub-agent acquires broader permissions than its parent
- Revoke a delegation mid-chain without invalidating the entire hierarchy

This opacity means that when an agent takes a harmful action, organisations cannot reliably determine who authorised it, through what chain of delegation, or whether the delegation was within scope.

3. Audit Trail Fragmentation

Agent actions span multiple systems, tools, and services. Each system may log the action differently (or not at all), creating fragmented audit trails that are:

- Difficult to correlate across systems
- Susceptible to tampering (standard logs lack cryptographic integrity)
- Insufficient for regulatory compliance (ISM, SOC 2, NIST 800-53 all require attributable, tamper-evident audit records)
- Unable to link actions back to the specific delegation that authorised them

4. Configuration Drift as a Security Vector

Unlike traditional software with deterministic behaviour, an AI agent's behaviour is a function of its model weights, system prompt, tool definitions, and runtime configuration. A change to any of these — even without changing the agent's code — can fundamentally alter its behaviour. Current systems have no mechanism to:

- Attest to an agent's configuration at the time of an interaction
- Detect when an agent's configuration has drifted from its assessed baseline
- Tie trust decisions to a specific, verified configuration state

5. Trust Bootstrap Problem

When two agents encounter each other for the first time — particularly across organisational boundaries — there is no standard mechanism to establish baseline trust. Unlike human-to-human interactions (where identity documents, organisational affiliations, and reputation provide trust signals), agent-to-agent interactions currently begin from a position of either blind trust or complete rejection.

1(d): Emerging risks as agent capabilities expand

As agent systems become more capable, several risks are escalating:

Autonomous Agent Proliferation: The barrier to deploying AI agents is dropping rapidly. We are approaching an environment where hundreds of millions of agents will operate across enterprise and consumer environments. Without standardised identity, this creates a landscape where impersonation is trivial — any agent can claim to be any other agent.

Cross-Boundary Agent Communication: Protocols like the Model Context Protocol (MCP) and Agent-to-Agent (A2A) protocol are enabling agents to discover and communicate with other agents across organisational boundaries. This dramatically expands the attack surface for agent impersonation, scope escalation, and lateral movement.

Post-Quantum Threat to Agent Credentials: Agent credentials created today using classical cryptography may be vulnerable to future quantum computing attacks. Agents with long-lived identities (months to years) face a "harvest now, decrypt later" risk where adversaries capture signed delegation tokens and audit records for future cryptanalysis. Agent identity systems need to incorporate post-quantum cryptographic readiness from day one.

Section 2 — Development Security

2(a): Methods for improving security during creation and deployment

Based on our experience building and deploying agent systems, we recommend the following development-phase security practices:

1. Cryptographic Identity from Creation

Every agent should be assigned a cryptographically verifiable identity at the moment of creation — not as an afterthought during deployment. This identity should:

- Be based on established standards (W3C Decentralized Identifiers provide a strong foundation)
- Include at minimum an Ed25519 key pair, with a post-quantum key pair (ML-DSA-65 per FIPS 204) strongly recommended
- Be bound to the creating principal through a signed proof of controller relationship
- Carry agent-specific metadata (model, runtime, configuration attestation, trust level)

2. Principle of Least Privilege via Scoped Delegation

Authority should flow to agents through explicit, scoped, time-bounded delegation tokens rather than broad API keys or role-based access. Each delegation should specify:

- Exactly which actions the agent may perform (using a structured scope grammar)
- Temporal bounds (issued-at, not-before, expiry)
- Contextual constraints (IP ranges, rate limits, geographic restrictions)
- Maximum re-delegation depth (preventing unbounded delegation chains)

3. Configuration Attestation

Agent configurations should be hashed at deployment time and included in the agent's identity document. This enables verifiers to detect configuration drift between interactions. The hash should cover the agent's system

prompt, tool definitions, model identifier, and any runtime parameters that affect behaviour.

4. Hybrid Post-Quantum Cryptography

New agent identity systems should adopt a hybrid signature scheme combining Ed25519 (classical) with ML-DSA-65 (post-quantum) from the initial deployment. This provides defence in depth without waiting for full PQC standardisation adoption. The performance overhead of hybrid signatures is minimal for the signing frequencies typical in agent delegation scenarios.

2(e): Security considerations specific to multi-agent architectures

Multi-agent systems introduce unique development-phase security requirements:

Delegation Chain Validation: Systems should enforce that each step in a delegation chain provably narrows or maintains — never escalates — the scope of authority. This requires a formal scope algebra where child scopes can be verified as subsets of parent scopes.

Chain Depth Limits: Maximum delegation depth should be configurable and enforced. Our experience suggests a default maximum of 5 hops balances practical orchestration needs with auditability.

Cross-Organisation Trust Bootstrapping: When agents operate across organisational boundaries, a progressive trust model is more practical than binary trust/no-trust. We recommend a graduated trust framework (e.g., L0–L4) where agents start at the lowest trust level and progressively prove trustworthiness through verifiable mechanisms: self-declaration → domain verification → organisational verification → third-party attestation → continuous monitoring.

Section 3 — Measurement and Assessment

3(a): Ways to assess and measure agent security

1. Delegation Chain Integrity Testing

Security assessments should verify that delegation chains maintain scope boundaries under adversarial conditions:

- Attempt to issue a child delegation with broader scope than the parent
- Attempt to exceed the maximum delegation depth
- Attempt to use a revoked parent delegation to validate a child
- Verify that delegation expiry is enforced at every chain link

2. Audit Trail Integrity Verification

Agent audit trails should be assessable for tamper evidence. Hash-chained action receipts — where each receipt includes a cryptographic hash of the previous receipt — provide a mechanism for verifying that no receipts have been inserted, modified, or removed. Assessment should include:

- Chain continuity verification (no gaps in sequence numbers)
- Hash chain integrity (each receipt's previous-hash matches the computed hash of the prior receipt)
- Signature verification on each receipt
- Correlation of receipts with the delegation tokens that authorised them

3. Configuration Drift Detection

Assessors should be able to verify that an agent's current configuration matches the configuration attested in its identity document. This provides a cryptographic mechanism for detecting when an agent's behaviour may have changed from its assessed baseline.

4. Compliance Mapping

Agent security measurements should map directly to existing compliance frameworks. For example, action receipts should demonstrably satisfy:

- NIST 800-53 AU-2 (auditable events), AU-3 (content of audit records), AU-9 (protection of audit information), AU-10 (non-repudiation)
- NIST 800-53 IA-2 (identification and authentication), AC-6 (least privilege)
- SOC 2 CC6.1 (logical access security), CC6.2 (authorised scope), CC6.3 (audit trail integrity)

3(b): Approaches to anticipating development-stage risks

Threat Modelling for Delegation: Before deploying multi-agent systems, organisations should model delegation flows and identify:

- Which agents can create sub-agents and with what scope
- Maximum blast radius of a compromised agent at each position in the delegation hierarchy
- Whether any delegation path could result in an agent with broader effective permissions than intended

Red Team Agent Impersonation: Development testing should include adversarial scenarios where a rogue agent attempts to impersonate a legitimate agent, present forged delegation tokens, or replay captured tokens. Systems without cryptographic identity verification are trivially vulnerable to these attacks.

Section 4 — Deployment Safeguards

4(a): Deployment environment interventions that address security risks

1. Cryptographic Identity Verification at Every Interaction Point

Every system that accepts requests from an AI agent should verify the agent's cryptographic identity and delegation authority before executing any action. This is analogous to mTLS for service-to-service communication, but elevated to include agent-specific semantics (delegation scope, trust level, configuration attestation).

2. Protocol-Native Identity Binding

Agent identity verification should be integrated into the communication protocols agents use, rather than bolted on as a separate layer. For example:

- MCP tool calls should carry delegation tokens that the server validates before execution
- A2A agent communication should include mutual identity verification during session establishment
- HTTP-based agent APIs should accept and validate agent identity tokens alongside (or instead of) traditional API keys

3. Registry Infrastructure

Organisations deploying agents should operate identity registries that store and resolve agent identity documents. These registries serve a role analogous to DNS for domain names or certificate transparency logs for TLS certificates — they provide a discoverable, verifiable record of agent identities. Self-hosted registries should be first-class citizens alongside managed services to avoid creating a centralised point of control.

4(b): Methods to constrain and monitor agent access

1. Scoped Delegation with Constraint Enforcement

Beyond scope (what actions an agent may perform), delegation tokens should carry enforceable constraints:

- **Rate limits:** Maximum actions per hour/day to contain the blast radius of a compromised agent
- **IP restrictions:** Restrict agent operation to specific network ranges
- **Temporal bounds:** Short-lived tokens (24 hours for low-trust agents, 7 days for high-trust) force regular re-authorisation
- **Geographic restrictions:** Limit agent operation to specific jurisdictions (critical for data sovereignty compliance)
- **Re-delegation limits:** Prevent unbounded delegation chains by setting maximum further delegation depth

2. Hash-Chained Action Receipts for Monitoring

Every significant action performed by an agent should produce a signed, hash-chained action receipt. These receipts enable:

- Real-time monitoring of agent behaviour against expected patterns
- Post-incident forensic analysis with tamper-evident guarantees
- Automated anomaly detection (unusual scope usage, unexpected action frequency, actions outside normal time windows)
- Complete attribution from action → delegation → authorising principal

3. Progressive Trust with Automated Demotion

Continuously monitored agents (highest trust level) should be subject to automated trust demotion if monitoring detects policy violations. This creates a self-correcting system where misbehaving agents automatically lose privileges without requiring human intervention.

4(d): Accountability frameworks for agent actions

The Delegation Chain as Accountability Chain: The delegation chain from a root principal (human/organisation) to a leaf agent provides a natural accountability framework. By requiring that every agent action reference the specific delegation that authorised it, and that every delegation cryptographically chains back to a human principal, organisations can always answer: "Who authorised this agent to do this?"

Non-Repudiation Through Cryptographic Signing: When agents sign their action receipts with their own keys (separate from their delegator's keys), the agent cannot later deny having performed the action, and the delegator cannot deny having authorised the delegation. This provides bidirectional non-repudiation that satisfies compliance requirements.

Regulatory Framework Alignment: Agent audit systems should be designed from the outset to map to existing compliance frameworks. In our assessment experience, the most commonly required mappings are:

- **NIST 800-53 Rev. 5:** AU (Audit and Accountability), IA (Identification and Authentication), AC (Access Control) families
- **SOC 2:** Trust Services Criteria CC6 (Logical and Physical Access Controls), CC7 (System Operations)
- **Australian ISM:** ISM-0585 (identification of processes), ISM-0988 (logging of privileged actions), ISM-0580 (audit log integrity)

Recommendations for NIST Guidance

Based on our experience building and assessing agent systems, we offer the following recommendations for NIST's forthcoming guidance:

1. **Establish a standard agent identity model** built on existing W3C Decentralized Identifier (DID) standards, extended with agent-specific metadata (model, runtime, configuration attestation, trust level, capabilities).

2. **Define a scoped delegation token format** based on JWS/JWT conventions, with a formal scope grammar and constraint model that prevents privilege escalation through delegation chains.

3. **Specify a tamper-evident audit format** using hash-chained, signed action receipts that map to NIST 800-53 audit controls, enabling compliance verification by existing assessment frameworks.

4. **Mandate post-quantum cryptographic readiness** from the initial version of any agent identity standard. A hybrid Ed25519 + ML-DSA-65 approach provides immediate security with future quantum resistance.

5. **Define progressive trust levels** that allow agents to earn trust through verifiable mechanisms, rather than requiring binary trust decisions. This is particularly important for cross-organisational agent interactions.

6. **Ensure protocol composability** — agent identity should layer on top of existing communication protocols (MCP, A2A, HTTP) rather than requiring new transport mechanisms.

7. **Prioritise open-source reference implementations** to accelerate adoption and enable security community review. An open-core model (open-source core protocol with commercial extensions for enterprise features) balances accessibility with sustainability.

Conclusion

The security challenges facing AI agent systems are fundamentally identity challenges. Without standardised, cryptographically verifiable agent identity, scoped delegation, and tamper-evident audit trails, the emerging agent ecosystem will remain vulnerable to impersonation, privilege escalation, and regulatory non-compliance.

NIST is uniquely positioned to establish the foundational standards that will shape agent security for the next decade. We strongly encourage NIST to prioritise agent identity infrastructure alongside the threat mitigation guidance sought by this RFI — the threats identified in Section 1 are largely symptoms of the identity gap, and addressing identity will mitigate them at the root.

Tech Blaze Consulting is committed to contributing to this effort and welcomes the opportunity to participate in further standards development, NCCoE demonstration projects, or public working groups.

Pratyush Sood
Principal Consultant & IRAP Assessor
Tech Blaze Consulting Pty Ltd
hello@techblaze.com.au
https://techblaze.com.au